

Lab 04 – End-to-End Mini Pentest in the Bachelor Lab Stack

Industrial Security (Master)

• Maps to Section 04

• 3–4 hours

LAB 04

🎯 Goal

Run a full mini-engagement against the Bachelor Docker lab stack: ROE → passive recon → active recon → one exploitation step → detection observation → report.

✂ Step 0 – Sign a fake ROE

Write the ROE for testing the Docker stack as if it were a real client. Self-sign as both tester and approver. Save it – you will reference it in the report.

✂ Step 1 – Passive recon

```
1 | cd bachelor/labs/_stack && docker compose up -d
2 | # 30 minutes of passive baseline:
3 | ls zeek-logs/current/
```

Note: which devices, which protocols, which talkers.

✂ Step 2 – Active recon (low-rate)

```
1 | docker compose exec student nmap -sT --max-rate 5 \
2 | --scan-delay 200ms -Pn -p 502,4840,1883,8080 172.28.0.0/24
```

Record which hosts respond on which ports.

✂ Step 3 – One exploitation step

```
1 | docker compose exec student python3 /labs/scripts/modbus_inject.py
```

Confirm in OpenPLC monitor that coil 0 flipped.

✂ Step 4 – Detection

Check Zeek's `notice.log` for the unsolicited-write notice. Document the time difference between attack and detection.

✂ Step 5 – Report

Produce a 2-page report with: ROE summary, recon findings, exploitation step (with PCAP excerpt), detection evidence, prioritised recommendations.

📁 Deliverable

The fake ROE, the recon and PCAP files, and the 2-page report. Hand in as a single PDF.

⚠ Caution

This whole sequence runs against your local Docker stack only. Performing any step against equipment you do not own without written authorisation is a criminal act under §202a StGB (and equivalents in other jurisdictions).